

## INFORME DE AUDITORÍA DE SEGURIDAD

Cliente / Objetivo .....: MegaCorp — 3.88.28.22 / megacorp.lab

Tipo de auditoría .....: Caja negra, externa

Auditor(es) .....: <nombre y apellidos>

Fecha de inicio .....: 2026/07/02

Fecha de fin .....: 2026/07/02

Versión del informe .....: 1.0

Clasificación .....: Confidencial

## RESUMEN EJECUTIVO

Informe de Auditoría de Seguridad — MegaCorp Lab

**Evaluación según metodologías OWASP ASVS / OWASP Testing Guide / PTES**

## Introducción y Alcance

### Contexto

Se realizó una auditoría de seguridad autorizada sobre la infraestructura expuesta del host:

- ⑩ **IP objetivo:** 3.88.28.22
- ⑩ **Modelo de despliegue:** Virtual hosts basados en cabecera Host
- ⑩ **Entorno simulado:** Caja blanca limitada con descubrimiento de servicios mediante enumeración activa

El objetivo fue identificar vulnerabilidades, configuraciones inseguras y exposición de información sensible, incluyendo la localización de indicadores de compromiso en formato **FLAG{...}**.

### Alcance técnico

Incluyó:

- ⑩ Enumeración de **virtual hosts** (vhosts)
- ⑩ Análisis de servicios web y APIs
- ⑩ Revisión de servicios expuestos (FTP, Redis, HTTP/HTTPS)
- ⑩ Inspección de certificados TLS
- ⑩ Búsqueda de información sensible accesible sin autenticación
- ⑩ Identificación de configuraciones inseguras en entornos dev/staging/internal

## VALORACION GLOBAL DEL RIESGO

### Evaluación general

#### **Riesgo Global: CRÍTICO**

La infraestructura presenta múltiples fallos graves de configuración que permiten:

- ⑩ Acceso no autenticado a servicios internos
- ⑩ Exposición de código fuente y datos sensibles
- ⑩ Enumeración de entornos internos mediante certificados TLS
- ⑩ Acceso a servicios críticos como Redis sin autenticación

## Justificación del riesgo

La combinación de:

- ⑩ **APIs sin autenticación**
- ⑩ **Servicios internos accesibles públicamente**
- ⑩ **Repositorios completos expuestos**
- ⑩ **Subdominios sensibles incluidos en certificados públicos**

incrementa de forma significativa la superficie de ataque y el riesgo de compromiso total del sistema.

## Principales conclusiones

- ⑩ Exposición completa de **repositorio Git** en producción.
- ⑩ Servicio **Redis accesible sin autenticación** desde Internet.
- ⑩ Enumeración de **subdominios internos** mediante SAN del certificado TLS.
- ⑩ Presencia de **entornos internos (dev/staging/internal)** accesibles públicamente.
- ⑩ Mala segregación de entornos y falta de controles de acceso.
- ⑩ Configuración insegura de virtual hosts que permite enumeración sistemática.

## Severidad de hallazgos

| Severidad | Nº de hallazgos |
|-----------|-----------------|
| Crítica   | 3               |
| Alta      | 2               |
| Media     | 1               |
| Baja      | 0               |

## HALLAZGOS DETALLADOS

### Hallazgo Crítico — Exposición de repositorio Git (.git)

**Categoría OWASP:** A05 – Security Misconfiguration **Descripción:** El directorio `.git/` es accesible públicamente, permitiendo descargar el repositorio completo, incluyendo historial, ramas y potencialmente credenciales o claves.

**Impacto:** Compromiso total del código fuente, ingeniería inversa, exposición de secretos.

#### Mitigación:

- ⑩ Eliminar `.git/` del entorno de producción.
- ⑩ Bloquear acceso mediante reglas del servidor web.
- ⑩ Implementar CI/CD seguro sin repositorios en producción.

### Hallazgo Crítico — Redis sin autenticación accesible públicamente

**Categoría OWASP:** A05 – Security Misconfiguration **Descripción:** El servicio Redis responde desde Internet sin requerir autenticación (`requirepass` deshabilitado).

**Impacto:** Acceso completo a la base de datos en memoria, modificación de datos, ejecución remota mediante módulos.

#### Mitigación:

- ⑩ Restringir Redis a `127.0.0.1`.
- ⑩ Activar `requirepass`.
- ⑩ Ubicar Redis detrás de VPN o red interna

### Hallazgo Crítico — Exposición de servicios internos

**Categoría OWASP:** A01 – Broken Access Control **Descripción:** Servicios internos accesibles mediante virtual hosts (`dev`, `internal`, `staging`) sin autenticación.

**Impacto:** Acceso a entornos no destinados al público, fuga de datos, acceso a herramientas internas.

#### Mitigación:

- ⑩ Segregar entornos.
- ⑩ Proteger con autenticación o VPN.
- ⑩ No exponer vhosts internos públicamente

### Hallazgo Alto — Enumeración de subdominios vía certificado TLS (SAN)

**Categoría OWASP:** A06 – Vulnerable and Outdated Components **Descripción:** El certificado TLS incluye subdominios sensibles en el campo SAN, permitiendo descubrir entornos internos.

**Impacto:** Facilita reconocimiento y enumeración de superficies internas.

**Mitigación:**

- ⑩ Emitir certificados separados por entorno.
- ⑩ No incluir subdominios internos en certificados públicos.

**Hallazgo Alto — Acceso a servicios internos sin restricciones**

**Categoría OWASP:** A05 – Security Misconfiguration **Descripción:** Servicios internos accesibles sin controles de acceso adecuados.

**Impacto:** Exposición de información sensible y ampliación de superficie de ataque.

**Mitigación:**

- ⑩ Implementar controles de acceso.
- ⑩ Segregar redes.
- ⑩ Revisar configuración de virtual hosts.

**Hallazgo Medio — Enumeración de virtual hosts**

**Categoría OWASP:** A07 – Identification and Authentication Failures **Descripción:** La configuración del servidor permite enumerar vhosts mediante diferencias en tamaño de respuesta.

**Impacto:** Facilita reconocimiento y descubrimiento de aplicaciones internas.

**Mitigación:**

- ⑩ Unificar respuestas de fallback.
- ⑩ Configurar virtual hosts con respuestas homogéneas.

**Recomendaciones Prioritarias (OWASP / PTES)**

1. **Eliminar exposición de .git en producción**
2. **Proteger Redis con autenticación y bind interno**
3. **Segregar entornos dev/staging/internal**
4. **Revisar certificados TLS para evitar filtración de SAN sensibles**
5. **Homogeneizar respuestas de fallback para evitar enumeración de vhosts**
6. **Implementar controles de acceso en servicios internos**

## Conclusión

La infraestructura presenta fallos críticos que permiten acceso no autenticado a servicios internos, exposición de código fuente y enumeración de entornos sensibles. La corrección de estas vulnerabilidades debe considerarse **prioritaria** para evitar compromisos mayores.

## ALCANCE Y REGLAS DE ENFRENTAMIENTO (RoE)

### Activos dentro de alcance

⑩ 3. 88. 28. 22 (host principal del laboratorio MegaCorp)

⑩ Virtual hosts asociados al mismo host:

- ⑩ www.megacorp.lab
- ⑩ dev.megacorp.lab
- ⑩ api.megacorp.lab
- ⑩ internal.megacorp.lab
- ⑩ staging.megacorp.lab
- ⑩ admin.megacorp.lab
- ⑩ vpn.megacorp.lab

**Servicios expuestos en el mismo objetivo:**

- ⑩ HTTP/HTTPS (80, 443)
- ⑩ FTP (21)
- ⑩ API REST (/v1/\*)
- ⑩ Servicio web en puerto 8080
- ⑩ Servicio interno en puerto 8000
- ⑩ Redis en puerto 6379

## **Activos fuera de alcance**

- ⑩ Cualquier otra IP externa a 3. 88. 28. 22
- ⑩ Infraestructura de Internet pública fuera del entorno del laboratorio
- ⑩ Sistemas de terceros no relacionados con MegaCorp
- ⑩ Cualquier servicio externo no expuesto por el host objetivo

## **Restricciones (RoE)**

Durante la auditoría se respetaron las siguientes restricciones:

- ⑩ No se realizaron ataques de denegación de servicio (DoS)
- ⑩ No se ejecutó fuerza bruta sobre SSH ni servicios críticos
- ⑩ No se realizó pivoting fuera del host objetivo
- ⑩ No se atacaron sistemas externos al alcance definido





